Chapter 13: Triage Before Treatment

Triage: Security Architecture for Small Business -Pre-release/Draft

Where is the rest of the book, Steven?

This is an excerpt from a book I've been working on for a couple of years. Triage: Security Architecture for Small Business is a practical guide to building and defending security architecture for organizations that have an aid bag, not a hospital: small and midsize businesses with one IT person or a small team, a limited budget, and no security operations center down the hall.

Its core argument is that small businesses can't fix everything, and they don't have to. Like a corpsman with limited supplies and multiple casualties, an SMB wins by knowing what kills first, acting in the right order, and preventing most casualties before they happen. Enterprise security frameworks aren't wrong, but they're tuned for a different environment, the way civilian ABC was tuned for the emergency room before combat medicine reordered priorities into MARCH based on evidence of what actually killed people. SMBs need priorities built for the field.

The author is a former Navy corpsman turned security practitioner, and that perspective shapes the book's approach to prioritization, decision-making under pressure, and incident handling.

The book follows the order a corpsman works in, across four parts: Assess (knowing what you protect, prioritizing with limited resources, and understanding how SMBs actually get hit), Prevent (eliminating whole classes of attack, Zero Trust identity, endpoints, and email), Architect the Terrain (cloud and SaaS, network segmentation, AI adoption and AI-enabled threats, and operational technology and the supply chain), and Respond and Recover (detection, incident response, ransomware recovery, and building readiness).

Every chapter follows the same four-part structure: Design It (the principles and decisions), Build It (hands-on implementation with tools SMBs already have), Break It (testing your own work in a lab or tabletop exercise), and Defend It (keeping it working over time). Each ends with a Monday Morning checklist.

A running case study, Meridian Supply Co., a 70-person distributor with Microsoft 365, cloud workloads, remote staff, and a warehouse with networked equipment, evolves across the book from "one IT person and a prayer" to a defensible architecture.

Chapter 13, Triage Before Treatment, is a candidate for the book's centerpiece. It adapts five emergency medicine protocols (METHANE, SMART, MARCH, SBAR, and MIST) into a first-hour incident response chain, and closes with a tabletop exercise small teams can run on their own.

It's the last evolution of a long week on SR-7, and you're one of two corpsmen on the range. Since morning, the LAV-25s have been working far targets with their 25mm guns while machine gun teams rotate through the firing line. The air smells like diesel and burnt gunpowder. The heat is finally going out of the day, and you're sitting in one of the HMMWV ambulances, thinking about a shower.

Ca-chung. Ca-chung. Ca-chung. The LAVs pound away, a machine gun rattles back, the sounds echo off the tree line.

The Range Safety Officer's voice booms over the loudspeaker from the tower: "Cease fire, cease fire on the line. Make all weapons safe." The call is repeated down the line. The machine guns stop first, then the 25s, until the only sound left is the LAVs idling.

Over that idle comes the yelling.

You're moving before you know why. Your aid bag is over your shoulder and your boots are finding the ground on their own. By the time you clear the vehicles, you can see the whole scene at once, and it's a lot.

Two bored Marines had climbed the stack of conex boxes at the edge of the range, where they had no business being. The top of the stack was still slick from the morning's rain. One slipped, grabbed the other, and they both came down. One of them is sitting up in the dirt, cradling his forearm, bent in a way forearms don't naturally bend. A small crowd has gathered around him, and nobody in it is talking.

Down the line, a gunner who was mid barrel change when the cease fire went up has grabbed the hot barrel with a bare hand. His palm is already blistering. He's loud. He's very loud. Every head on the range keeps turning toward him.

The other Marine from the fall is sitting with his back against the conex, one leg folded under him. He lifts a hand when he sees you. "I'm good, Doc. Just landed weird." He looks embarrassed more than anything.

Your training says one thing. Your feet say another. They're carrying you toward the yelling.

You make it two steps before a hand closes on your arm. Doc Reyes, the senior corpsman, has come up behind you, breathing hard from the run. He isn't looking at the burn. He isn't looking at the arm either.

"Loud means breathing," he says. "Check the quiet one."

So you do. Up close, the Marine who said fine is far from fine. His face has gone the color of old paper. His skin is cool and damp despite the heat, and the pulse under your fingers is fast and thin. You can't see anything visibly wrong with him, and that's what scares you.

You run your gloved hands down his legs and under him, the way you've drilled a hundred times. Your hand comes back red. Not a smear. Soaked.

He came down on a pile of scrap metal beside the conex, and a jagged piece of steel went deep into the back of his thigh. His camouflage hid the blood, and the dirt and sand under him soaked it up. He's been sitting quietly in a dark patch nobody could see, telling everyone he's good.

Your hands know what to do before your head catches up. Tourniquet out, 2 to 3 inches above the wound. You crank the windlass until the bleeding stops, and he finally makes noise, and you don't mind, because noise means he's still with you. You leave the steel where it is and pad around it so it can't shift. Then you write the time on the tourniquet, because everyone who touches him from here on will need to know exactly how long it's been on.

Behind you, Reyes has the burn cooling and the arm splinted. Both of those Marines are hurt. Both can wait. You send a couple of Marines nearby to grab a litter while you go over the report in your head: what happened, what you found, the tourniquet and its time, how his vitals were trending, and everything you'd done. While he is being loaded into the ambulance, Reyes is on the phone to the naval hospital with the report, so the trauma team will be waiting at the door instead of finding out when he arrives.

He'll be fine. He'll be fine because somebody looked past the noise, and because you stopped the bleeding before you did anything else.

That afternoon is fiction, a composite of the scenarios every corpsman trains for. The lesson isn't. In triage, the loudest casualty is rarely the one in the most danger. The one who should worry you is the one who isn't making a sound.

Nobody at Meridian Supply Co. will ever face a scene like that. The first hour of a cyber incident tests the same thing: whether you go to the noise, or to what's actually killing you.

At 4:47 on a Friday afternoon, Ray Okafor, the warehouse manager at Meridian Supply Co., called the IT office. The shipping system was acting strange. Files on the shared drive had new names, long strings of random characters ending in an extension nobody recognized. A text file had appeared in every folder. He wanted to know if it was a Windows update thing.

Dana Ruiz, Meridian's IT lead and, for most practical purposes, its entire IT department, already had her jacket on. She had a choice to make, and she had about ninety seconds to make it well.

She could walk to the warehouse and look at Ray's screen. She could open the file server and start reading the text file. She could search the strange extension online and try to figure out which ransomware family this was. She could call the managed service provider, the cyber insurance company, the CEO, her spouse to say she'd be late. All of those things would eventually need to happen. Most of them, done first, would make the next forty-eight hours worse.

What happens in the next sixty minutes will decide how this ends for Meridian.

13.1 Why the First Hour Goes Wrong

When businesses look back on a bad incident, the failure is rarely a lack of technical skill. The person in charge usually knew how to isolate a machine, reset a password, or restore a backup. What went wrong was the order. They started treating before they triaged.

Premature treatment looks reasonable in the moment. It feels like action, and action feels like progress. Some common themes:

The IT person wipes and reimages the first infected computer, which removes the immediate problem and also destroys the evidence of how the attacker got in. The attacker is still inside, and the same thing happens again on Tuesday.

Someone chases the first alert. They spend an hour investigating the one machine that triggered a warning while the attacker moves quietly through three others.

Someone calls everyone at once. The MSP, a security vendor they found online, the bank, a friend who "does cyber." Now four parties are making changes, nobody is writing anything down, and the insurance policy may have been violated before anyone read it.

Someone starts the investigation before stopping the damage. Understanding the malware is interesting. It is also the last thing that matters while files are still being encrypted.

None of these people are incompetent. They are under stress, and stress narrows thinking. Under pressure, people grab the first task in front of them, fixate on details, and lose track of the bigger picture. Medicine learned this a long time ago, which is why emergency care runs on short, memorable protocols rather than improvisation. A protocol isn't a sign that you don't know what you're doing. It's what you lean on precisely when your judgment is most likely to fail.

In the introduction, I described how combat medicine changed its order of operations from ABC to MARCH when the evidence showed that uncontrolled bleeding, not airway problems, was killing people who could have been saved. The lesson carries over directly. The order you do things in during the first hour matters as much as the things themselves, and the right order comes from evidence about what actually causes harm, not from habit.

> **Sidebar: Don't Wipe the Patient**
>
> The instinct to wipe an infected machine and move on is strong, especially for a busy IT person who just wants things working again. Resist it in the first hour. That machine holds the evidence of how the attacker got in, what they touched, and whether they're still present. Destroy it, and you lose the ability to close the door they came through. It can also complicate an insurance claim and any legal or regulatory obligations that follow. Isolate the machine instead: disconnect it from the network, but leave it powered on unless your incident response provider tells you otherwise, since some evidence lives only in memory. You can rebuild it later, once someone has all of the pertinent information.

Design It: The Protocol Chain

13.2 The Chain at a Glance

This chapter uses five protocols borrowed from emergency medicine and adapted for cyber incidents. Each one answers a single question, and they run in order:

Step	Protocol	The question it answers
1	**METHANE**	Is this an incident, and what do we know?
2	**SMART**	What's affected, and in what priority?
3	**MARCH**	For each top-priority item, what do we do first?
4	**SBAR**	What does leadership need to decide?
5	**MIST**	What does the next responder need to take over?

Figure 13.1: The protocol chain. A printable version is in the companion kit on GitHub.

In practice the steps overlap. You will be re-sorting with SMART while you work through MARCH, and you may brief leadership more than once. When you lose track of where you are, and you will, come back to the chain and ask which question you're answering right now.

The chain also assumes a few roles. In a large company, each is a different person. In a small one, they may all be you.

The **incident lead** runs the response and makes technical calls. The **scribe** writes down everything: what happened, when, who did what, and what was decided. The **communications** role handles who gets told what, internally and externally. The **business decision-maker**, usually the owner or CEO, makes the calls that trade operations against security, such as shutting down a system the business depends on.

> **Sidebar: When You're One Person**
>
> If you are the whole IT department, you can't split yourself four ways. Prioritize the roles this way: incident lead first, because someone has to drive. Scribe second, and this is the one most solo responders drop, which is a mistake. Hand it to anyone who can type and stay calm. An office manager is often ideal. Their notes will become your MIST handoff, your insurance claim, and your memory of a night you'll otherwise remember as a blur. Decision-maker third: get the owner on the phone early, even if only to say "I'll need a decision from you within the hour." Communications can wait the longest, but not forever.

At Meridian, Dana takes her jacket off. She asks Ray not to touch anything else, not to turn anything off, and to keep his team off the shared drive. Then she walks to Jenny Reese's desk. Jenny runs the front office and accounts payable, and she's the most organized person in the building. Dana asks her to open a blank document, put the time at the top, and write down everything that happens from here on.

13.3 METHANE: Declaring the Incident

The first protocol in the chain comes from major incident response, where emergency services use it to share a quick, structured picture of a scene. Its first job in a cyber incident is simpler and more important than it sounds: it makes you say, out loud and in writing, that this is an incident.

Declaring matters because it changes behavior. Before the declaration, people treat strange events as glitches and keep working normally. After it, everyone knows the rules have changed. Declaring also starts clocks you may not know are running, including insurance notification requirements and, depending on your industry and location, legal notification deadlines.

Each letter becomes one line of your initial report:

M - Major incident declared. State it plainly: "I'm declaring a security incident." Write down the time.

E - Exact location. Which systems, sites, and cloud services are involved, as far as you know right now. Be specific: "the file server at the main office," not "the network."

T - Type of incident. Your best current guess: ransomware, business email compromise, data theft, insider activity, or unknown. "Unknown" is a perfectly good answer at this stage.

H - Hazards. What could make things worse? Is the attacker still active? Are backups connected to the affected systems? Are any operational or safety systems involved, like the warehouse equipment? Is anyone at risk of a fraudulent payment going out?

A - Access. How will responders get in if normal access is compromised? This means break-glass administrator accounts, out-of-band communication channels in case email is compromised, and physical access to the building after hours.

N - Number affected. Users, systems, records, and locations, as best you can estimate. This will change. Write down what you know and update it.

E - Emergency services. Who needs to be called: your cyber insurer's hotline, your incident response provider, legal counsel, and in some cases law enforcement.

At 4:58 PM, Dana says the words out loud to Jenny, who writes them down. Dana's METHANE report, typed in a text message to herself so she doesn't lose it, looks like this:

M: Declared security incident 4:58 PM Friday.

E: Main office file server. Possibly the shipping workstation in the warehouse. Unknown if cloud is affected.

T: Likely ransomware. Files renamed, ransom note in folders.

H: May still be active. Backup server is on the same network. Warehouse PLCs on the same flat network segment as shipping. Jenny has a vendor payment batch scheduled Monday.

A: Break-glass credentials assumed safe, not yet verified. Using personal phone for calls in case email is compromised.

N: At least 1 server, 1 workstation. Users unknown.

E: Insurer hotline. CEO. MSP.

It took four minutes, is incomplete and partly wrong, and that's fine. This is the starting picture, and every person she talks to tonight will get a clearer briefing because of it.

Sidebar: Call Your Insurer First

If your business carries cyber insurance, read your policy now, before an incident. Many policies require you to call the insurer's breach hotline before engaging outside vendors, and to use the incident response firms, lawyers, and other providers on the insurer's approved panel. Hiring your own firm first can reduce or jeopardize your coverage. The call is usually short: you report the incident, get a claim number, and the insurer connects you with a response firm. Make that call early, but don't let it delay containment. You can start stopping the bleeding while you wait for a callback.

Dana calls the insurer's hotline at 5:02. The call takes six minutes. She gets a claim number and a promise that an incident response firm will call her back within the hour. She doesn't wait for that callback to keep going.

13.4 SMART: Sorting What's Affected

At a mass casualty scene, the first medic to arrive faces more patients than hands. Treating the first person you reach is the natural instinct and most likely the wrong one. Triage systems exist to replace gut instinct with a fast, consistent sort, so the limited care available goes to where it can do the most good.

The SMART triage approach works in two passes. The first, the sieve, is fast and rough: a quick look at everyone to decide who needs help right now. The second, the sort, is more careful and happens once the immediate threats are handled. Cyber incidents benefit from the same two passes. Your first sort will be quick and partly wrong. A fast, rough sort beats a perfect one that arrives an hour late.

Sort every affected or possibly affected asset (systems, accounts, data, and services) into one of four categories:

Immediate. Actively compromised or under attack, or a crown-jewel asset at direct risk. These get attention now. Examples: a server currently being encrypted, an administrator account the attacker controls, a backup system connected to the infected network.

Urgent. Exposed or suspicious, but not actively bleeding. These need attention soon, after the Immediate items are stabilized. Examples: workstations on the same network segment, accounts that share passwords with a compromised account, the line-of-business application everyone depends on.

Delayed. Apparently unaffected, but needs to be watched. Examples: cloud services with separate authentication, systems on a separate network segment.

Expectant. Assets that are better rebuilt than saved. Trying to clean them would cost more time and carry more risk than restoring from a known-good source. Examples: a workstation that was the attacker's first foothold, a server where the attacker had full administrative control for weeks.

Asset	Category	Why	Next action

Figure 13.2: The SMART sort sheet. A printable version is in the companion kit on GitHub.

The Expectant conversation. The hardest category to use is the last one. Telling a business owner that a system they paid for, configured, and depend on is not worth saving is a difficult conversation, and small business owners resist it for understandable reasons: money, time, and the fear that rebuilding will take longer than cleaning.

In security terms, a system the attacker fully controlled can never be completely trusted again. You can remove the malware you find, but you can't prove you found all of it. Rebuilding from known-good images and restoring clean data is usually faster and safer than an uncertain cleanup. Make the case to the owner in business terms: "We can spend two or more days trying to clean this and still not be sure, or spend one day rebuilding it and know it's clean."

Triage is continuous. New information will arrive, and when it does, re-sort. An Urgent workstation becomes Immediate the moment you see the attacker on it. A Delayed cloud service moves up when you discover the compromised account also had access there. If everything is marked Immediate, nothing is. Revisit the sort every time something significant changes, and have the scribe record each change.

At 5:10, Dana runs her first sort with Jenny writing:

> **Immediate:** File server (actively encrypting). Backup server (same network, reachable). The domain admin account, which is the only account with access to both.
>
> **Urgent:** Shipping workstation. ERP server. All other office workstations.
>
> **Delayed:** Microsoft 365 (separate authentication, but watch for sign-ins). Warehouse PLCs (no sign of activity, but on the same flat network).
>
> **Expectant:** None yet.

The backup server isn't showing any signs or symptoms of damage yet. Dana puts it in Immediate anyway, because if the attacker reaches it, Meridian loses its way back. That's triage: not just what's hurt the most, but what's most likely to kill your company.

Loud means breathing. The file server is the one screaming, and it still needs you. The backup server is the quiet one.

13.5 MARCH: Treating in Order

Stop the bleeding. Start the breathing.

SMART tells you which assets need attention first. MARCH tells you what to do for each of them, and in what order. In combat medicine, MARCH is the sequence for treating a casualty: massive hemorrhage, airway, respiration, circulation, and hypothermia or head injury. Its power is the order itself. You don't move to the next letter until the current one is handled, no matter how tempting the next problem looks.

Applied to a cyber incident, each letter becomes a stage of containment and stabilization.

	Medical	Incident response
M	Massive hemorrhage	Stop the active loss, data exfiltration, encryption, spread
A	Airway	Secure identity and communications
R	Respiration	Keep critical business functions running
C	Circulation	Protect backups and money flows
H	Hypothermia / Head injury	Preserve evidence and prevent the slow decline

Figure 13.3: MARCH applied to incident response.

M - Stop the active loss. Nothing else matters until the bleeding stops. For a cyber incident, bleeding means anything the attacker is actively doing: encrypting files, exfiltrating data, lateral movement to new systems, or sending fraudulent emails. Stop it with the fastest effective measure available. Disconnect affected systems from the network. Disable compromised accounts and revoke their active sessions and tokens, since a password reset alone may not log

out an attacker who already has a session. Block outbound connections to known attacker infrastructure if you can identify it. Speed beats elegance here. A pulled network cable is crude, but it is effective.

A - Secure identity and communications. In medicine, everything depends on the airway. In a modern business, everything depends on identity: the accounts and the system that controls them. If the attacker controls your administrator accounts or your identity provider, every other fix can be undone. Confirm that your break-glass accounts work and haven't been touched, reset credentials for privileged accounts, and review recent changes to administrator roles and sign-in policies. At the same time, move your response communications out of band. If your email or chat platform may be compromised, assume the attacker can read them, and coordinate by phone or through accounts outside the company's systems.

This is where the medical comparison bends the most. An airway and an identity system aren't really alike, except in one way that matters: when either fails, nothing downstream works, no matter how well you treat it.

R - Keep critical business functions running. A business that survives an attack but can't operate for two weeks may not survive the recovery. Identify the functions that keep the business alive (taking orders, shipping, payroll, customer communication) and find manual or alternative methods to keep them going. Paper order forms, phone-based customer updates, and a payroll call to your provider are not glamorous, and they buy time.

C - Protect backups and money flows. Circulation is about what moves through the business: data and cash. Attackers increasingly go after backups specifically because destroyed backups make a ransom payment far more likely. Verify that your backups are intact, isolated from the compromised network, and haven't been altered. On the money side, freeze or manually verify any outgoing payments, especially if email may be compromised. Attackers who are inside a mail system often redirect vendor payments, and the money rarely comes back.

H - Preserve evidence and prevent the slow decline. In combat medicine, hypothermia and head injuries are the threats that quietly kill a patient who seemed otherwise stable. Cyber incidents have their own slow threats. Logs roll over and disappear, often within hours or days, so export and preserve them now. Attackers whose access wasn't fully removed come back, so watch for reinfection. People wear down: a multi-day incident run by one exhausted person leads to mistakes. Set shifts if possible, send people home to sleep, and keep the scribe's log going so nobody has to rely on memory.

> **Sidebar: Tourniquet Decisions**
>
> For years, tourniquets were treated as a last resort in emergency care, feared for the damage they could cause. The evidence from modern conflicts reversed that view. Applied early and correctly, they save lives that would otherwise be lost.

> Small businesses have their own tourniquets: disconnecting the entire company from the internet, shutting down a core system, disabling the owner's account, or closing operations for a day. Owners fear these moves because they hurt, though sometimes they are exactly the right call. If you can't tell how far an attack has spread and it's actively causing damage, the broad, painful measure that stops it everywhere is often better than a precise one that stops it in some places.
>
> Tourniquets also have time limits, which is why the time gets written on every one. Leave the tourniquet on too long and it causes additional harm. The same applies here. A full shutdown buys time to understand the situation, and then you convert it into more targeted measures as quickly as you safely can. Decide in advance, in writing, who has the authority to apply a tourniquet. At 5 PM on a Friday is the wrong time to debate it.

At Meridian, Dana works through the letters in order.

For **M**, she pulls the network cables on the file server and the shipping workstation at 5:18, and disables the domain admin account. Then she pauses. She doesn't know how far this has spread, and the warehouse network is flat. She calls Marcus Hale, Meridian's CEO, and gets his approval for a tourniquet: disconnecting the office from the internet entirely. The connection goes dark at 5:31.

While isolating the file server, she notices something interesting in a temporary folder: a file that looks like the malware itself. Part of her wants to dig in immediately. She tells Jenny to write down the folder path and leaves it alone. It will still be there when she gets back to it, and the malware will matter much more to the incident response firm than to her right now anyway.

For **A**, she logs into Microsoft 365 over a hotspot data connection, confirms admin and break-glass accounts haven't been used unexpectedly, checks for new administrators or unusual sign-ins, and resets the passwords for every administrator account. A reset doesn't end a session already in progress, so she revokes active sessions for each of those accounts too. Calls about the incident move to personal phones.

At 5:36 she calls Meridian's MSP. She keeps it to three minutes: there's an incident, the insurer is bringing in a response firm, and she needs the MSP to suspend their remote access to Meridian and make no changes until the firm says otherwise. She asks one question: has their tooling seen anything unusual today? Nothing so far.

For **R**, Jenny and Ray set up paper order forms for Monday morning and a script for customer service.

For **C**, Dana confirms that the backup server is disconnected and that last night's offline backup copy, stored in the cloud with immutability turned on, is intact. Jenny puts a hold on Monday's payment batch until each vendor's bank details are confirmed by phone.

For **H**, Dana exports the firewall logs and Microsoft 365 audit logs to an external drive, and tells Jenny to plan for a second person to take over the scribe role if this runs into Saturday.

13.6 SBAR: Briefing Leadership

Hospitals adopted SBAR as a way for nurses to brief physicians quickly and clearly, so critical information doesn't get lost in a rushed conversation. It works just as well for briefing a business owner in the middle of an incident, because both conversations have the same problem: one person has detailed technical information, and the other has to make a decision.

Situation. What is happening right now, in one or two sentences.

Background. The relevant context: what happened, what's been done so far.

Assessment. What you think it means: how bad it is, what's at risk, what you don't know yet.

Recommendation. What you recommend, ending with a specific decision you need from them, and by when.

A good SBAR takes about sixty seconds. The most common mistakes are too much technical detail, which loses the listener; no recommendation, which leaves the decision-maker guessing; and asking leadership to solve a technical problem rather than make a business decision. The owner doesn't need to understand ransomware. They need to understand the trade-off you're asking them to make.

When Marcus arrives at 5:45, Dana gives him this:

> **Situation:** We have a ransomware attack. The file server is encrypted and the attacker may have reached other systems.
>
> **Background:** Ray reported it at 4:47. I declared an incident at 4:58, notified our insurer, asked our MSP to suspend remote access, and we've disconnected the office from the internet with your approval. Our backups look intact and are isolated.
>
> **Assessment:** We've stopped the active damage as far as we can tell. We don't yet know how they got in, whether they took data, or whether the warehouse network is affected. The insurer's response firm is calling within the hour.
>
> **Recommendation:** I recommend we keep the warehouse shut down tonight and keep shipping on hold until the response firm confirms the warehouse network is clean. That likely delays Monday morning's shipments. I need your decision on that in the next thirty minutes so Ray can notify the drivers.

Figure 13.4: Meridian's SBAR to the CEO.

Marcus asks two questions and approves the shutdown. The whole conversation takes four minutes.

13.7 MIST: Handing Off

When a casualty moves from one level of care to the next, the handoff is one of the most dangerous moments. Information gets lost, assumptions get passed along as facts, and the receiving team wastes time asking questions the first team already answered. Military medics use MIST to make handoffs fast and complete.

In a cyber incident, the handoff usually goes to an incident response firm, a managed detection and response provider, or the insurer. Each letter becomes part of your report:

M - Mechanism. How the attacker got in, if known, or your best hypothesis. "Unknown" is acceptable. Say what you suspect and why.

I - Injuries. What's affected: systems, accounts, data, and services, using your SMART sort.

S - Signs. What you've observed: indicators of compromise, file names, suspicious accounts, unusual traffic, the ransom note, and the current status of each affected system.

T - Treatment. Everything you've done so far, with times. This is the part responders most need and most often don't get, because it determines what evidence still exists and what they can trust.

The test of a good MIST handoff is simple: could the receiving team start working without asking you a basic question? If they have to ask what time it started, which systems you disconnected, or whether anyone rebooted the server, the handoff failed.

A good handoff also starts before the patient arrives. On the range, the naval hospital got a call while the ambulance was still loading, so the trauma team was ready instead of surprised. In a cyber incident, that's the early call to your insurer and response firm, made while you're still containing, so they're preparing while you work.

At 6:04, the response firm calls. The lead responder has a few minutes before she assembles her team, so Dana gives her the short version: likely ransomware, file server encrypted, office offline since 5:31, backups look clean, nothing wiped. The responder asks Dana to keep everything powered on and call back at 7:15 with a full report. Dana spends the hour in between walking the warehouse with Ray and building the report from Jenny's log.

This is where the scribe pays off. A MIST report built from memory at 7 PM on a stressful night is full of gaps. One built from Jenny's timestamped log takes ten minutes and is nearly complete.

Dana calls the incident response firm back at 7:15 and reads them this:

> **Mechanism:** Unknown. Best guess is the domain admin account, which was the only account with access to both the file server and the backup server. That account doesn't have MFA on internal logons. No phishing reports this week.
>
> **Injuries:** File server encrypted. Shipping workstation shows renamed files. Backup server reachable from the infected network but appears untouched. Microsoft 365 shows no unusual activity so far. Warehouse PLCs on the same network, no sign of impact.
>
> **Signs:** Files renamed with a random extension, ransom note in every folder. Suspected malware file found in a temp folder on the file server; path recorded, not opened. No unusual outbound traffic seen yet, but we haven't reviewed it fully.
>
> **Treatment:** 4:58 incident declared. 5:02 insurer notified, claim number on file. 5:18 file server and shipping workstation disconnected, left powered on; domain admin disabled. 5:20 CEO approved full internet disconnect; office offline at 5:31. Admin passwords reset and active sessions revoked in Microsoft 365. 5:36 MSP asked to suspend remote access and make no changes. Backup server disconnected; offline cloud backup verified intact. Monday's vendor payment batch on hold pending phone verification of bank details. Firewall and Microsoft 365 audit logs exported to external drive. 6:04 initial brief to response firm. Nothing rebooted, nothing wiped.

Figure 13.5: Meridian's MIST handoff to the incident response firm.

The lead responder's first question is about scheduling a time to come onsite. That's the sign of a good handoff.

Build It: The Response Kit

Everything in this chapter works better if it's prepared before you need it. Build a response kit now, while things are calm, and you'll spend the first hour of an incident following it rather than inventing it.

A complete kit for a small business includes:

- **The protocol card** (Figure 13.1), printed and posted where the IT lead and owner can find it.
- **Templates** for METHANE, the SMART sort, SBAR, and MIST, ready to fill in.
- **A contact list** with your insurer's breach hotline and policy number, your incident response firm or retainer, your MSP, legal counsel, your bank's fraud line, and a law enforcement contact. Include after-hours numbers.
- **Break-glass account procedures**: where the credentials are stored, who can access them, and how to use them.
- **An out-of-band communications plan**: which phones and accounts you'll use if email and chat are compromised.

- **A printed incident log**: a simple form with columns for time, action, person, and notes, so the scribe can start immediately.

Store the kit where an incident can't reach it. Keep a printed binder in the office and a copy in at least one location outside your company's systems, such as a personal cloud account belonging to the owner. A response plan stored only on the file server that just got encrypted is not a response plan.

Finally, pre-decide your tourniquets. Write down who has the authority to disconnect the internet, shut down a core system, or freeze payments, and under what conditions. Dana had to call Marcus for approval at 5:20. That worked because Marcus answered his phone. Next time he might be on a plane.

Templates for the full kit are in the companion kit on GitHub.

Break It: The Tabletop Exercise

Protocols only work under stress if they've been practiced without it. A tabletop exercise is a guided walk-through of an incident scenario, run around a conference table, where participants talk through what they would do. Nothing on the network is touched. You don't need a consultant to run one, though it helps to have one person act as facilitator rather than participant.

Who should attend. The owner or CEO, the IT lead and anyone who supports IT (including your MSP if possible/applicable), whoever would act as scribe, and the person who handles finance. Six to eight people is ideal.

Time required. About two hours, including a hot wash/debrief.

Materials. Printed copies of the protocol card and templates, the inject cards below, a clock that everyone can see, and the scoring rubric for the facilitator.

The scenario. Use Meridian's Friday afternoon, adapted to your own company's systems and people. Read the opening scenario aloud, then deliver each inject on a card at the indicated time.

Inject 1 (0:00) - First report. A warehouse or front-office employee calls IT: files have strange names and a text file appeared in every folder. *Expected: someone declares an incident and produces a METHANE report.*

Inject 2 (0:10) - Initial findings. The file server and one workstation show renamed files. The backup server is on the same network. *Expected: a SMART sort, with the backup server correctly placed in Immediate.*

Inject 3 (0:20) - The temptation. The IT person finds what looks like the malware file and is excited to analyze it. *Expected: the team notes it, leaves it alone, and finishes stopping the*

bleeding first. This is the inject most teams fail, and it's designed to tempt them.

Inject 4 (0:35) - The CEO walks in. The owner wants to know what's going on. *Expected: a sixty-second SBAR ending with a clear decision request.*

Inject 5 (0:50) - New information. A second account shows suspicious sign-ins, including one to email. *Expected: a re-sort, with email moving up, and a move to out-of-band communications if not already done.*

Inject 6 (1:05) - The incident response firm calls. *Expected: a MIST handoff delivered from the scribe's notes.*

Inject 7 (1:20) - The insurer calls with questions. *Expected: a second MIST-style report. This tests whether the scribe kept good notes and whether the team's story is consistent.*

Protocol	Order	Completeness	Clarity	Time
METHANE				
SMART				
MARCH				
SBAR				
MIST				

Figure 13.6: Scoring rubric. Score each cell 1–3. Order matters most: a complete response done in the wrong order still fails.

Facilitator tips. Keep the pressure realistic by enforcing the clock. Don't let the exercise turn into a technical debate about how the ransomware works. Redirect to the protocol: "Which question are you answering right now?" Make the owner participate as the decision-maker rather than an observer. Debrief immediately while memories are fresh.

Variants. Once your team has run the ransomware scenario, try a business email compromise variant, in which an attacker inside the mailbox redirects a vendor payment, and an insider variant, in which a departing employee downloads customer data. The same protocol chain applies, but the priorities shift in useful ways.

Defend It: After Action

Every exercise and every real incident should end with an after-action review. Military units call the immediate version a hot wash: a short debrief held right away, before people scatter and actions become memories.

Ask three questions. What didn't work? What worked? What will we change? Keep it blameless. The goal is to fix the process, not assign fault, and people who fear blame stop telling you the truth.

Then update the kit. Every exercise reveals something: a phone number that's out of date, a break-glass password nobody could find, an owner who didn't know they were the decision-maker. Fix each one, and write down who's responsible for the fix and by when.

Run the tabletop at least once a year, and again after major changes: a new IT lead, a new owner, a move to a new system, or a significant change in staff. Protocols decay when the people who practiced them leave.

At Meridian, the incident took four days to fully resolve. The response firm found that the attacker had come in through a remote access account belonging to a former contractor, which nobody had disabled. Meridian's offline backups held, and the company was shipping again by Wednesday, without paying a ransom. Six weeks later, they ran their first tabletop exercise. The biggest lesson was that Dana had been the only person who knew where the break-glass credentials were. Now three people do.

Monday Morning Checklist

- Print the protocol card and post it where the IT lead and owner will see it.
- Name your incident roles: incident lead, scribe, communications, and decision-maker, plus a backup for each.
- Confirm your insurer's breach hotline, policy number, and requirements for using approved vendors.
- Confirm your incident response contact, MSP contact, legal counsel, and bank fraud line.
- Decide, in writing, who has tourniquet authority.
- Store the response kit somewhere an incident can't reach it.
- Schedule your first tabletop exercise.

Meridian's first hour went well because Dana triaged before she treated. She stopped the bleeding, protected what kept the business breathing, and handed off cleanly to the people who could finish the job. Stopping the bleeding is only the beginning. Back in the Circulation step, she confirmed that Meridian's backups were intact. In the next chapter, Meridian has to use them.